MEDICAL IMAGE AI PIPELINE

MIAP

Project explainer and handover for group members who did not take part in the build

What was required, what was actually built, what changed and why, how the system protects patients and data, and what still has to happen before any clinical use.

DECISION SUPPORT ONLY · NOT A DIAGNOSTIC DEVICE

Prepared for
MIAP project group, Biomedical Engineering, Mbarara University of Science and Technology

Period covered
9–10 November 2026 (MVP build cycle)

Scope authority
MIAP_MVP_Pipeline.md, Specific Objective 3, Phase 1

Document date
10 November 2026

Contents

A reading guide for new group members. Sections 2, 3 and 9 answer “what was asked, what exists, what changed”. Sections 5 and 11 explain the safety boundaries.

1	Executive summary	3
2	The original requirements	5
3	What was actually built	8
4	Architecture	11
5	Security, privacy and governance	14
6	How each role uses MIAP	17
7	Models and AI outputs	21
8	Reports and model governance	24
9	What changed from the original plan	26
10	Verification and evidence	30
11	Why decision support, not diagnostic	32
12	Current limits and open items	34
13	Running and exploring the project	36
14	Glossary and file map	38
A	Result document v2	40
B	Roles and endpoints	42
C	Evidence index	44

How to read the status labels

BUILT

Implemented and covered by tests or recorded evidence.

CHANGED

The original requirement was met in a different way. The reason is given.

DEFERRED

Deliberately not built in this cycle. It is a known gap, not an accident.

Everything labelled **ADDED** was not in the original MVP document. It was added because the system needed it to be usable, safe or auditable.

In this document

- The requirements baseline and where it came from.
- What was built, screen by screen and path by path.
- Every material change from the plan, with its reason.
- Security, privacy and governance boundaries.
- How each role works and what it may see.
- Model provenance, approvals and measured limits.
- How to run, test and verify the system.
- A glossary, file map and evidence index.

Deliberately not in this document

- No patient data, uploads or DICOM files.
- No keys, passwords, tokens or environment values.
- No copy of the locally held MIAS dataset.
- No claim of clinical validation or regulatory approval.
- No revenue, procurement or staffing plan.
- No substitute for `docs/API.md` when integrating.

1. Executive summary

MIAP is an offline, CPU-only decision-support prototype for medical images. It takes a chest X-ray, a mammogram study or a limb X-ray, de-identifies it, routes it to an approved model, and presents findings, an overall impression, a heatmap and a report to the right role. It is built to be demonstrated and audited, not to diagnose.

3	3	3 · 1 · 1	271
clinical image paths: chest X-ray, mammogram density, limb X-ray	roles: clinician, researcher, administrator	approved models, one candidate, one hidden internal router; the candidate cannot be selected	backend tests passing on 10 November 2026

The original MVP document (*MIAP_MVP_Pipeline.md*, 9 November 2026) described a broad first phase: twelve screens, three X-ray capability areas, mammogram four-view handling, and later AI models. That plan was used as the scope authority, but the build deliberately narrowed it to a **vertical slice that works end to end** and added the safety and governance layers the original document did not specify. The most important changes are:

- **The chest path is complete:** upload, de-identification, routing, TorchXRayVision DenseNet-121 inference, per-finding Grad-CAM, review, PDF report and audit.
- **Mammography gained a real model:** MONAI breast-density classification (BI-RADS-style A–D) per view, with an exam-level summary per breast. It remains density only — not cancer detection, not a malignancy probability.
- **The upper-limb and fracture plan changed:** instead of training MURA and FracAtlas models in this cycle, the build uses a zero-shot SigLIP 2 bone model for limb and hand X-rays, with hip/pelvis marked experimental. There is no fracture box detector.
- **Patient identity became a first-class, encrypted layer** that is deliberately separate from image de-identification. Only the clinician who owns the case can read it, and every read is audited before the data is returned.
- **The result now states a conclusion.** A server-computed *impression* names the leading pattern, the density category, or the absence of a review-band finding, so the workspace and both PDF audiences say the same thing.
- **The interface was consolidated:** twelve planned screens became role-specific routes around one unified study workspace; reviews happen inline; all non-critical disclaimers are combined into one safety notice per screen.
- **Governance is real, not cosmetic:** model cards, licences, SHA-256 verification, benchmark gates, administrator approvals, a hash-chained audit log and three separate report audiences.

What MIAP is not

It is not a diagnosis, not a tuberculosis screen and not a cancer screen. Scores are uncalibrated; the review bands are qualitative. No model has been validated on Ugandan or local patients, and the benchmarks measure speed, memory and heatmap sanity, not accuracy. Every clinical surface says this, and section 11 explains the distinction in detail.

What a new group member should take away

The codebase is a working reference implementation of a safe medical-imaging pipeline. If you inherit it, you inherit four things: a clear clinical boundary (decision support, human review), a privacy boundary (de-identified images are separate from encrypted identity), a governance boundary (only approved models can run, and every sensitive action is audited), and a documented list of what is still missing (section 12).

All screenshots in this document were captured from the running application on 10 November 2026. The patient names are demo pseudonyms; no real patient data is present.

Where to start, by background

If you are…	Read first	What you will probably own
Clinician or clinical supervisor	2, 3.3, 6, 8, 11	Review policy, what counts as a finding, report wording and escalation.
Researcher or data scientist	5, 7, 10, Appendix A	Model selection, datasets, validation design and pseudonymised exports.
Administrator or governance officer	5, 8, 10, 12	Accounts, model approvals, retention runs and audit verification.
Developer or maintainer	4, 10, 13, 14	Environment, migrations, test suite, releases and evidence capture.
Supervisor or assessor	1, 2, 9, 11, 12	Scope decisions, the evidence trail, and the open items list.

2. The original requirements

This section summarises the document the build was measured against, so that changes in section 9 have a clear baseline. The original document is *MIAP_MVP_Pipeline.md*, dated 9 November 2026, covering Specific Objective 3, Phase 1 (MVP), for X-ray and mammogram only.

2.1 Scope and principles

In the original MVP

- X-ray in three capability areas: chest, upper limb, fracture/long bone.
- Other body regions are recognised but answered with “not supported yet”.
- Mammogram: four-view exam handling first; AI models after the plumbing works.
- Three roles with different screens: clinician, researcher, administrator.
- One modality router, then specialist models. Fusion later.

Out of the original MVP

- CT, MRI, pathology and dermoscopy.
- PACS/EHR integration and federated learning.
- Clinical validation and regulatory approval.
- Real multi-view fusion.
- DICOM SEG export, lesion detection and segmentation in the first pass.

The original document set five principles that still govern the build: decision support only, never an autonomous diagnosis; BI-RADS and supporting findings kept separate from any malignancy probability; DICOM orientation, laterality, view and pixel information preserved from the first step; patient-level rather than image-level splits when training and testing; and backend enforcement, because hiding a button is not security.

2.2 Roles and the twelve planned screens

#	Planned screen	Clinician	Researcher	Administrator
01	Dashboard	Own recent cases, pending analyses	Own cases, experiments, batch jobs	System health, queue, user activity
02	New Case	Single study upload	Single and batch upload	No access
03	Case Library	Own cases only	Own plus research-shared; bulk export	Metadata only, no images
04	Image Workspace	Viewer, window/level, zoom, measure	Same, plus raw output layers	No access
05	Analysis	Auto-selected model, one Run button	Model choice, thresholds, preprocessing, batch	No access
06	Results	Findings, confidence, heatmap, BI-RADS support	Same plus raw JSON, masks, CSV	No access
07	Reports	Generate and export PDF	PDF plus research export	Manage templates

#	Planned screen	Clinician	Researcher	Administrator
08	Model Library	Read-only: purpose and limits	Full: compare, cards, performance	Enable/disable, versions, register weights
09	Dataset Manager	No access	Register datasets, splits, labels	Storage use, access approvals
10	Evaluation	No access	Run evaluations, view metrics	View only
11	Settings	Account and viewer defaults	Account plus default parameters	System settings
12	Administration	No access	No access	Users, permissions, audit log

2.3 The X-ray capability plan

Area	Regions	Task	Model and data named	Original MVP
A	Chest PA/AP	Multi-finding classification	TorchXRayVision DenseNet-121	Yes
B	Wrist, hand, elbow, shoulder	Normal vs abnormal	MURA dataset (needs training)	Yes
C	Bones in hand, leg, hip, shoulder	Fracture detection with boxes	FracAtlas plus YOLO (needs training)	Yes
D	Spine, pelvis	Later: segmentation then pathology	“FleXray + dedicated datasets”	Recognised only
E	Head/skull, abdomen	Later: dedicated models	Dedicated datasets	Recognised only

The original document warned that MURA and FracAtlas are datasets, not ready-made models; areas B and C would probably require training or fine-tuning, while area A had pretrained weights ready to use. It also flagged that FleXray could not be confirmed as suitable and that every dataset licence needed checking.

2.4 The thirteen pipeline stages

#	Stage	Original purpose and tools	Original MVP status
1	Ingestion	Accept DICOM/PNG/JPEG, store safely, create a case; FastAPI, pydicom, Pillow, SQLAlchemy/SQLite.	P1
2	Validation and de-identification	Check pixels and tags; remove identity; pseudonymise; validation receipt.	P1
3	Router 1: modality	X-ray vs mammogram from DICOM metadata, fallback classifier, manual override.	P1
4	Router 2 / organiser	X-ray body region; mammogram laterality and view, group the four-view exam.	P1
5	Preprocessing	Windowing, normalisation, resizing; mammograms keep high resolution.	P1 X-ray, P2 mammogram patches
6	Specialist inference	Chest, upper-limb and fracture models; mammogram classification, detection, segmentation.	P1 chest, P2 limb/fracture, P2–P3 mammogram
7	Explainability	Grad-CAM, boxes, masks, confidence, BI-RADS/density as separate fields.	P2

#	Stage	Original purpose and tools	Original MVP status
8	Results store	One predictable JSON contract; SQLite plus files; model name and version recorded.	P1
9	Viewer and results screens	Cornerstone3D, window/level, overlays, four-view mammogram layout.	P1 plain, P2 overlays
10	Report	PDF/JSON/CSV, decision-support statement, mammogram exam report.	P2
11	Model development and evaluation	Training, patient-level splits, external validation, metrics, model cards.	P2; scripts matter more than a screen
12	Security, users and audit	JWT, RBAC, password hashing, audit log, pseudonymisation, TLS.	P1-lite, rest P2
13	Deployment and compute	Docker/Nginx, CPU inference, offline operation, hardware gate.	P0 hardware test, then P2

2.5 Build order and risks

Original build order

1. **0** Hardware test: PyTorch import and one DenseNet-121 inference.
2. **1** Ingestion, de-identification, login and three roles.
3. **2** Modality and region routers, mammogram four-view grouping.
4. **3** Cornerstone viewer, plain images, four-view layout.
5. **4** Chest inference end to end with heatmap.
6. **5** Upper-limb and fracture models.
7. **6** Mammogram classification.
8. **7** Evaluation scripts, Model Library, report polish.
9. **8** Mammogram detection and segmentation.

Risks the original document named

- Weak laptop hardware; test PyTorch first.
- Mammography models were the least certain part.
- Two of three X-ray areas needed training, not just weights.
- Dataset access (VinDr-Mammo, MURA) takes time and agreements.
- No metadata means no router: fallback and manual override are essential.
- Public datasets do not represent local patients.
- BI-RADS is not a cancer probability.
- Previous team's reported numbers were unverified and must not be reused.

2.6 Open decisions in the original document

Open decision	What the build did
Confirm the three X-ray areas, or swap area C	Kept chest and limb; replaced the planned trained models with a zero-shot bone model. No fracture detector was built.
Where inference runs	Local CPU, single process, offline. No GPU and no cloud dependency.
How much mammography is in the MVP	Four-view loading, grouping and viewer, plus breast-density AI. No cancer, BI-RADS or malignancy model.
May the administrator ever see images	No. Enforced by the backend on every pixel, file, preview, heatmap and case-report route.
Who owns backend, frontend and models	Not recorded in the repository. This remains a team decision and should be written down for the next cycle.

3. What was actually built

The delivered system is a single FastAPI application with a React front end. It serves the API and runs inference in the same process, stores images and results on local disk, and uses SQLite in WAL mode. It runs offline on a CPU and needs no GPU, container or cloud service.

Dimension	As built on 10 November 2026
Image paths	Chest X-ray (multi-finding + CAM), mammogram (per-view density A–D + exam summary), limb/hand X-ray (zero-shot normal vs abnormal; hip/pelvis experimental).
Models presented	`chest_densenet121` (approved), `monai_density` (approved through governance), `siglip_bone` (approved, not locally validated), `mammoscreen` (candidate, unselectable). One internal router model is hidden.
Roles	Clinician, researcher, administrator, each with a different dashboard, navigation, permissions and report audience.
Identity	Separate encrypted patient record, owner-only and audited. Images remain de-identified with no re-identification key.
Review	Confirm or dismiss each finding, optional encrypted note, progress count, inline in the workspace.
Reports	Clinician PDF (identity, plain language, decisions, notes); researcher PDF (pseudonym, scores, provenance, agreement counts, no notes); governance PDF (no patients, pixels or findings).
Audit	Append-only hash-chained events, in-app verification, NDJSON export, independent verifier script. Identity reads are committed before the payload is returned.
API surface	Approximately 50 operations across 19 backend modules; 16 runtime database tables.
Verification	271 backend tests, clean TypeScript typecheck, recorded benchmark JSON, screenshots and PDFs in `docs/evidence/`.

3.1 End-to-end flow

1. Create
Patient and study, or link an existing patient. Consent and retention are recorded.
owner-scoped case

2. Upload
DICOM, PNG or JPEG. Size and type are checked; the de-identification receipt is stored.
original bytes discarded

3. Route
Modality, body region, laterality and view. A capability bucket is chosen.
chest · bone_limb · bone_hip_pelvis · mammogram_density

4. Analyse
An approved model is selected and queued. The worker loads de-identified pixels and runs the model and CAM.
single CPU worker

5. Present
Immutable result is upgraded on read to v2: bands, plain language, impression, review state, heatmaps.
UI and PDFs agree

6. Review
Clinician confirms or dismisses findings and can add an encrypted note.
audited

7. Report
A role-specific PDF is rendered from the same stored result and audited.
3 audiences

The model never sees the patient identity. It sees a de-identified image stored under a content hash. The identity record is linked to the *case*, not to the image, and only the clinician owner can open it. This is the most important architectural boundary in the system and is explained again in section 5.

3.2 From the twelve planned screens to the routes that exist

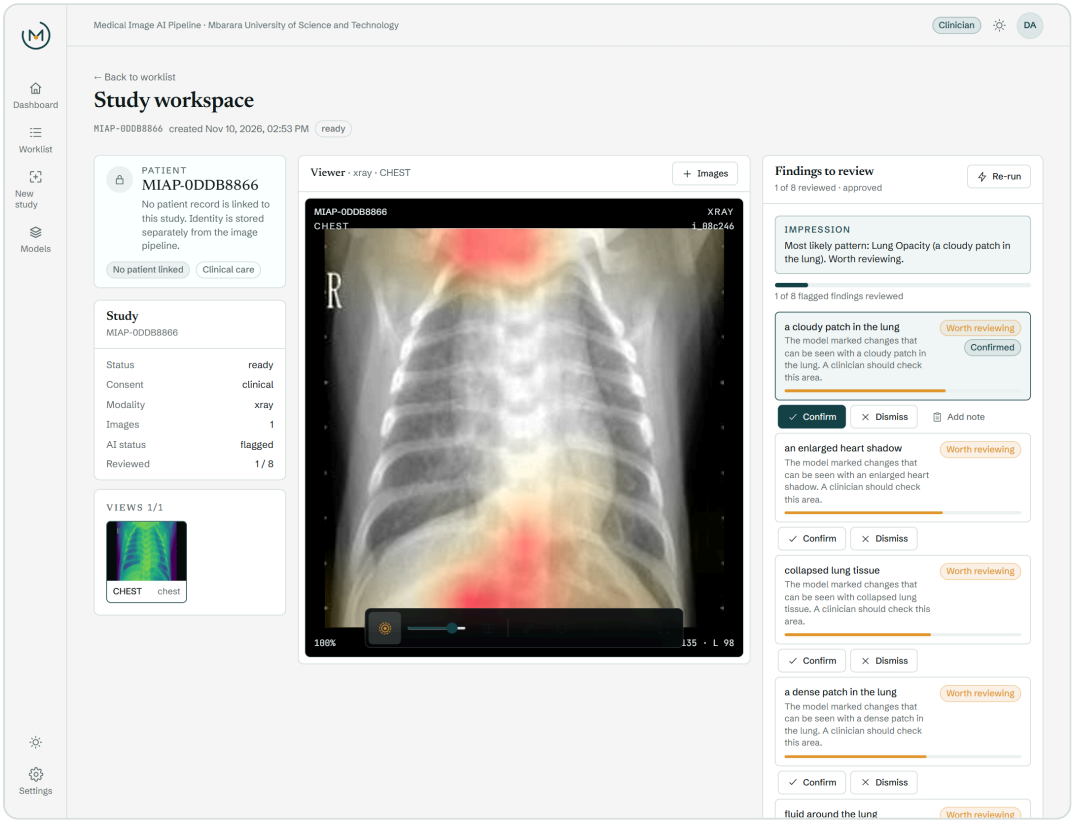
Original screen	What exists now	How it changed
01 Dashboard	`/`, role-specific	Three different dashboards: clinical work, research dataset/batches, governance and health.
02 New Case	`/cases/new`, `/patients/new`	Split into study creation and encrypted patient creation, because identity and images are separate systems.
03 Case Library	`/worklist` (clinician), `/research` (researcher), admin Studies	One filterable worklist with server-side sorting, AI flag, review progress and role-scoped columns.
04 Image Workspace	`/cases/:caseId` — one unified workspace	Viewer, analysis, findings, review, CAM and report actions were merged into one three-column page. A legacy `/results/:jobId` URL redirects into it.
05 Analysis		
06 Results		
07 Reports	Report panel in the workspace; `/admin/audit` for governance PDF	Audience chosen by role; no template-management screen.
08 Model Library	`/models`, `/admin/models`	Read-only library for clinical roles; approval decisions for administrators.
09 Dataset Manager	`/research`, `/research/batches`	Partial: dataset counts, research-consent cases, batch runs and pseudonymised exports. No dataset registration or split editor.
10 Evaluation	Offline scripts in `ml/benchmark/`	No evaluation screen. Benchmarks produce JSON evidence used by the approval gate.
11 Settings	`/settings`	Profile, theme, viewer defaults; researcher defaults; administrator system policy.
12 Administration	`/admin/users`, `/admin/audit`, `/admin/health`, `/admin/retention`, `/admin/models`	Expanded into separate governance pages. Administration never receives image bytes or clinical findings.

3.3 Role capabilities as enforced by the server

Capability	Clinician	Researcher	Administrator
Create cases and upload images	Yes	Yes	No
Patient identity (name, hospital number, DOB)	Owner only, audited	Never	Never
Read image bytes, previews, heatmaps	Own cases	Own plus research consent	**Never**
Submit single, batch or exam analysis	Yes	Yes	No

Capability	Clinician	Researcher	Administrator
Read results and findings	Own cases	Own plus research consent	Job status only
Confirm or dismiss findings, notes	Owner	Counts only	No
Case report	Own, with identity	Research, pseudonymised	No case report
Governance PDF	No	No	Yes
Users, approvals, retention, health, audit	No	Read-only models	Yes
Dataset export	No	Yes, pseudonymised	No

3.4 What the system looks like

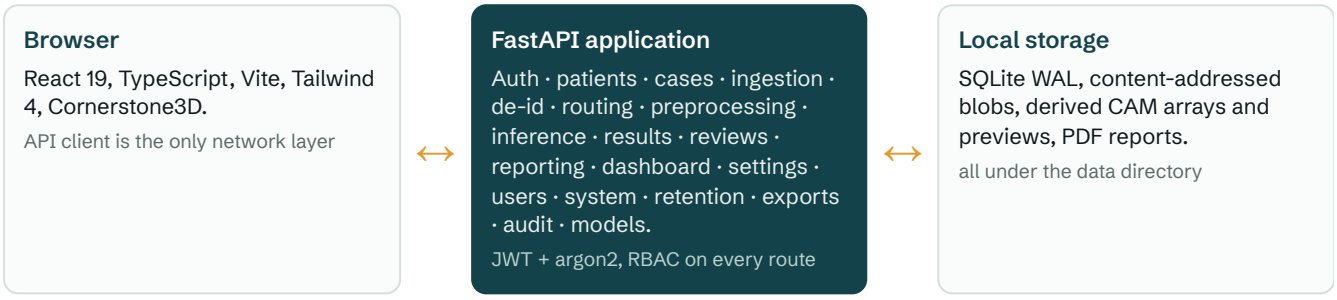


Unified study workspace. Patient and study facts on the left, a sticky viewer in the centre, and findings on the right. The server-computed impression appears before the evidence list; Confirm, Dismiss and Add note act inline without opening a dialog. The patient shown is a demo pseudonym with no linked identity record: in normal use the clinician owner sees a name banner here, while researchers and administrators see the pseudonym and a restriction note. Administrators never see the viewer at all.

4. Architecture

A modular monolith with one deployable process. The boundary is deliberate: a solo/small team can run and debug it, while module boundaries keep the option to split later. The same process serves the API and runs inference on a dedicated worker thread so a slow model cannot block requests.

4.1 Runtime topology



In-process CPU worker

An asyncio queue consumed by one dedicated thread. Jobs left queued or running are re-queued on startup; a job interrupted twice fails as `interrupted` instead of retrying forever.

Model cache

Engine factory keyed by model id and version, `lru_cache(maxsize=4)`, registry digest checked on load.

Offline

No network at runtime. Weights are fetched once by a script and verified by SHA-256.

4.2 Backend modules

Module	Responsibility
`core`	Settings, database sessions, numbered migrations, AES-GCM crypto envelope, JWT/argon2, audit chain, blob store, problem+json errors.
`auth`	Login and current-user resolution.
`patients`	Encrypted identity, hospital-number blind index, audited reads, case linking.
`cases`	Create, list, detail, archive; sorting, filters, AI flag, review counts, admin metadata view.
`ingestion`	Upload limit, type sniffing, de-identification, pixel validation, preview generation.
`deid`	PS3.15 basic-profile subset, UID remapping, raster EXIF strip, receipt.
`routing`	Modality and body-region resolution, mammogram four-view grouping.
`preprocessing`	Pixel loading and model input profiles (size, crop, channels, mean/std).
`inference`	Capability routing, model selection, job queue, batch and exam jobs, engine adapters, Grad-CAM.
`results`	Immutable result document, v2 presenter, plain language, impression, provenance, heatmap artefacts.
`reviews`	Confirm/dismiss findings, encrypted notes, owner-only note reads.
`reporting`	Audience-aware A4 PDFs rendered from the stored JSON result.
`dashboard`	Role-specific landing payloads.

Module	Responsibility
`settings`	Personal preferences, system settings, server-provided capability matrix.
`users`	Administrator user lifecycle, including password reset.
`system`	Health, storage, queue and model-cache summary.
`retention`	Due-study preview and confirmed deletion run.
`exports`	Pseudonymised researcher export, row-capped and audited.
`audit`	Hash-chained event export and verification.
`models`	Registry, seeded versions, approval history and projection.

4.3 Storage and data artefacts

```
# runtime layout (gitignored)
data/
  miap.db                                  SQLite, WAL mode
  blobs/sha256/ab/cd/abcd...               de-identified image bytes, content-addressed
  derived/<case_id>/<image_id>/heatmap.npy   primary CAM, float32
  derived/<case_id>/<image_id>/heatmap_3.npy per-finding CAM, computed on first request
  derived/<case_id>/<image_id>/heatmap.png  RGBA preview for reports
  reports/<report_id>.pdf                  generated PDF reports
  backups/                                 migration rehearsals and backups
```

Blobs are immutable and addressed by the SHA-256 of the stored (de-identified) bytes. Writes go through a temporary file and an atomic rename. Paths in SQLite are relative to the data directory and resolved through a guard that rejects traversal. The original upload bytes are discarded; only the digest of the original is recorded next to the stored digest.

4.4 Database and migrations

The database has 16 runtime tables: `users`, `patients`, `cases`, `images`, `jobs`, `results`, `provenance`, `finding_reviews`, `result_heatmaps`, `analysis_batches`, `reports`, `audit_events`, `model_versions`, `model_approvals`, `app_settings` and `user_prefs`.

SQLAlchemy's `create_all` cannot alter an existing table, so startup applies numbered SQL files before `create_all`. A `schema_migrations` table records version, timestamp and checksum. A pre-runner database is baselined at version 1 by stamping the reviewed snapshot; each new file runs in one transaction with foreign keys off, followed by `PRAGMA foreign_key_check`; a checksum mismatch refuses startup and names the file. This replaced the original plan's Alembic, which was disproportionate for a single-node SQLite MVP (ADR-016).

4.5 Front end and viewer

- **One API client** (`src/api/client.ts`) attaches the bearer token, parses problem+json into a typed error, and handles authenticated downloads.
- **One Cornerstone rendering engine** per page, reference-counted. Multiple engines produced separate WebGL contexts and intermittent blank panes; a single context renders the four mammogram views reliably.
- **Server-decoded pixels:** the browser fetches raw samples plus an `X-MIAP-Meta` header. The browser never decodes DICOM, so every accepted transfer syntax works.

- **CAM overlay** is a 2D canvas over the WebGL canvas, mapped back through image geometry and viewport coordinates. The measured hotspot agreed with the stored CAM argmax within 0.4% of image width.
- **Viewer interaction:** wheel zoom, primary-drag pan, right-drag window/level, double-click reset, pinch/double-tap on touch, length tool only in measure mode, floating auto-hiding control bar, before/after split, per-view chips, keyboard shortcuts.

4.6 Deployment and failure behaviour

Deployment as built

- Python 3.13, Node 22+, no GPU, no Docker, no internet at runtime.
- `scripts/dev.ps1` starts the backend on :8000 and Vite on :5173.
- SQLite single node; no horizontal scaling or object storage.
- TLS is expected from a deployment proxy; development is HTTP.

Failure rules

- Unsupported region or modality: `409 analysis_not_supported` naming the bucket.
- Candidate or out-of-scope model: `409 model_not_approved` or `model_scope_mismatch`.
- Worker failure: job `failed` with a code; never a guessed result.
- Missing mammogram view: explicit placeholder, not an empty pane.
- Decode failure: 422 with a stable code; nothing partial is stored.

5. Security, privacy and governance

MIAP keeps two things apart on purpose: what is removed from an image, and what a clinician is allowed to know about the person. Confusing those two is the most common misunderstanding about the project, so this section starts there.

5.1 Two separate boundaries

Image lane

Upload → tag removal and UID remapping → de-identified bytes stored under SHA-256. The original bytes are discarded and the remapping key is not retained.

there is no image → person path

Identity lane

Clinician enters name, hospital number, sex and date of birth → one AES-256-GCM ciphertext with a blind index for exact lookup.

linked to the case, never derived from pixels

Deleting the patient row therefore removes the only link between a study and a person. The image remains a de-identified research object. Conversely, the identity record contains no pixel data or image-derived value. This separation is documented in *docs/DEID.md* and enforced by separate tables, permissions and audit events.

5.2 Encrypted identity

Property	Implementation
Cipher	AES-256-GCM. One ciphertext per patient containing canonical JSON `{name, hospital_number, sex, dob}`.
Associated data	Binds the ciphertext to `patient:<id>:v<version>`, so a ciphertext cannot be swapped between records.
Lookup	HMAC-SHA256 blind index over the normalised hospital number using a separate key. Exact match only; no plaintext search.
Keys	`MIAP_PII_KEY`, `MIAP_PII_INDEX_KEY`, `MIAP_PII_KEY_VERSION`. The app refuses to start without the PII key. Tests use fixed keys; production keys are generated into the gitignored `backend/.env`.
Rotation	`scripts/rotate_pii.py --to N` re-encrypts in batches; old versions remain readable through `MIAP_PII_KEYS`. Rotation audits counts only.
Review notes	Same envelope, AAD `review:<id>`. Researchers see `has_note`, never the text.
Failure behaviour	No name, hospital number, DOB or note text is ever logged or returned in an error. Decryption failure returns `422 identity_decrypt_failed` with no detail.

5.3 Access control

Authentication is email and password with argon2 hashing and a JWT (HS256, 8-hour default). Authorisation is enforced on the server by dependencies: `require_roles`, `require_image_reader` (rejects administrators), `require_identity_reader` (clinicians only) and `require_patient_owner` (404 for a

patient outside the caller's scope, to avoid leaking existence). Every case read is scoped by `can_access_case`.

> **The administrator rule**
>
> Administrators are refused image bytes, previews, heatmaps and case reports with `403 images_forbidden`. They can see case metadata, job status, counts, model approvals, audit and health — but never pixels, findings, identity, notes or a clinical report. A separate governance PDF gives them the operational picture without clinical content. This was verified against the running app, not just the tests.

5.4 Audit trail

Events are append-only and hash-chained: each row stores a sequence number, the previous hash and its own hash. Every login, case, image, analysis, result, review, report, identity view, model approval, settings change, retention run and export is recorded. Detail fields contain identifiers, field *names* and counts — never values.

Identity reads are the deliberate exception to the rule that GETs do not write. Before an identity payload is returned, the server commits a `patient.identity_viewed` event through its own session with `BEGIN IMMEDIATE`. If the audit write fails, the read fails closed with 503 and no identity is returned. The chain can be verified in the app or independently with `scripts/verify_audit.py`, which rejects a tampered export.

5.5 De-identification profile

DICOM (fixed PS3.15 subset)

- Names, IDs, accession/study IDs, institutions, physicians, operators, station/device details and descriptions are replaced or emptied.
- Dates and times of care, demographics and signatures are removed. All private tags are removed.
- Every instance UID is remapped with HMAC-SHA-256 to `2.25.<128-bit>`; class UIDs and transfer syntax are preserved.
- Orientation, laterality, view, geometry, calibration and acquisition technique are retained for display and interpretation.

Raster (PNG/JPEG)

- Re-encoded, dropping EXIF, XMP and embedded ICC profiles.
- The receipt warns that modality and body region had to be chosen manually or guessed.
- If DICOM declares burned-in annotation, the receipt warns that pixel text cannot be removed; MIAP does not alter pixels or attempt OCR.
- Every upload returns a receipt listing what was replaced, removed and retained. `reidentification_key_retained` is always false.

5.6 Data protection and lawful basis

Health data is special personal data under Uganda's Data Protection and Privacy Act, 2019. The identity layer therefore requires a documented lawful basis, owner-only access, audited reads and a retention decision. Until the ethics and data-protection review is complete, the project uses synthetic or demonstration patients only. The MIAS sample set is kept local and is not committed because of its research licence.

5.7 What the security tests cover

- Crypto round-trip and AAD swap rejection; database-byte and audit-detail scans for identity values; no PII in captured logs.

- The full RBAC matrix, including administrator denial on every content route and foreign-patient 404s.
- Identity-view audit ordering and chain verification; fail-closed behaviour when the audit write fails.
- Review-note visibility: owner sees the note, researcher sees only `has_note`, administrator sees neither.
- Report audience separation: clinician PDF contains identity and notes; researcher PDF contains neither; governance PDF contains no patients, pixels or findings.

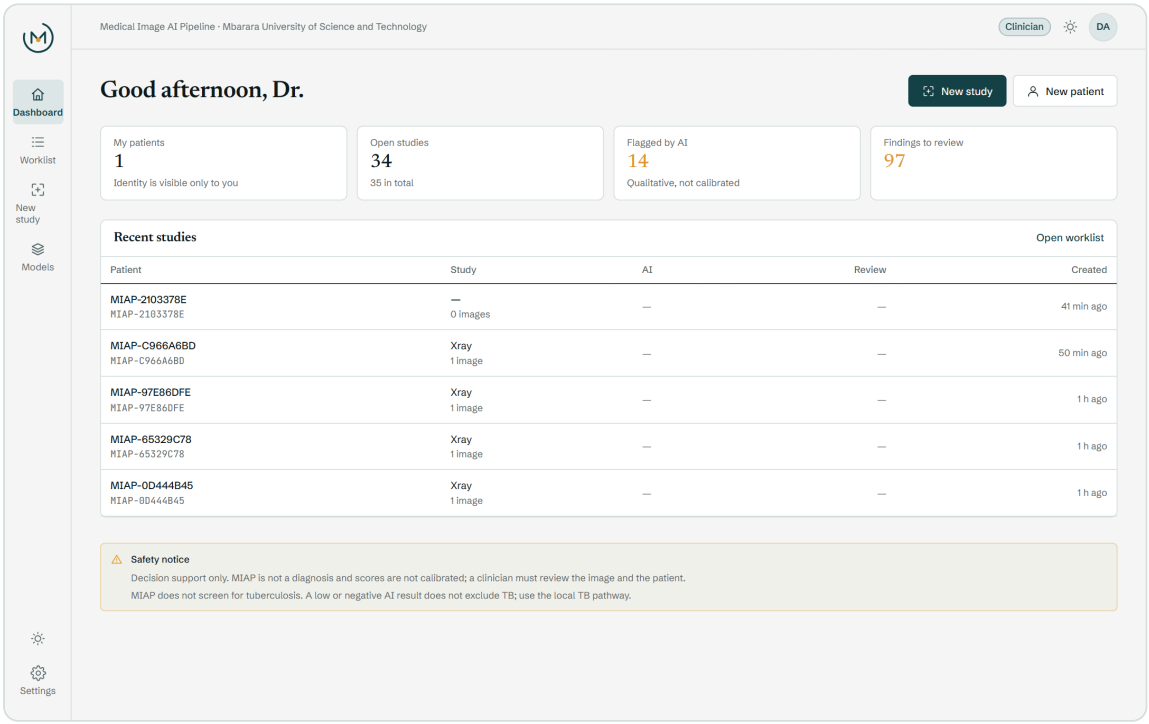
> **Honest limits**
>
> The audit chain is tamper-evident, not tamper-proof: someone with write access to the database file can replace the whole chain. The `BEGIN IMMEDIATE` design assumes a single application process. De-identification is a fixed subset and cannot detect identifiers burned into pixels or hidden in free text. These are documented gaps, not solved problems.

6. How each role uses MIAP

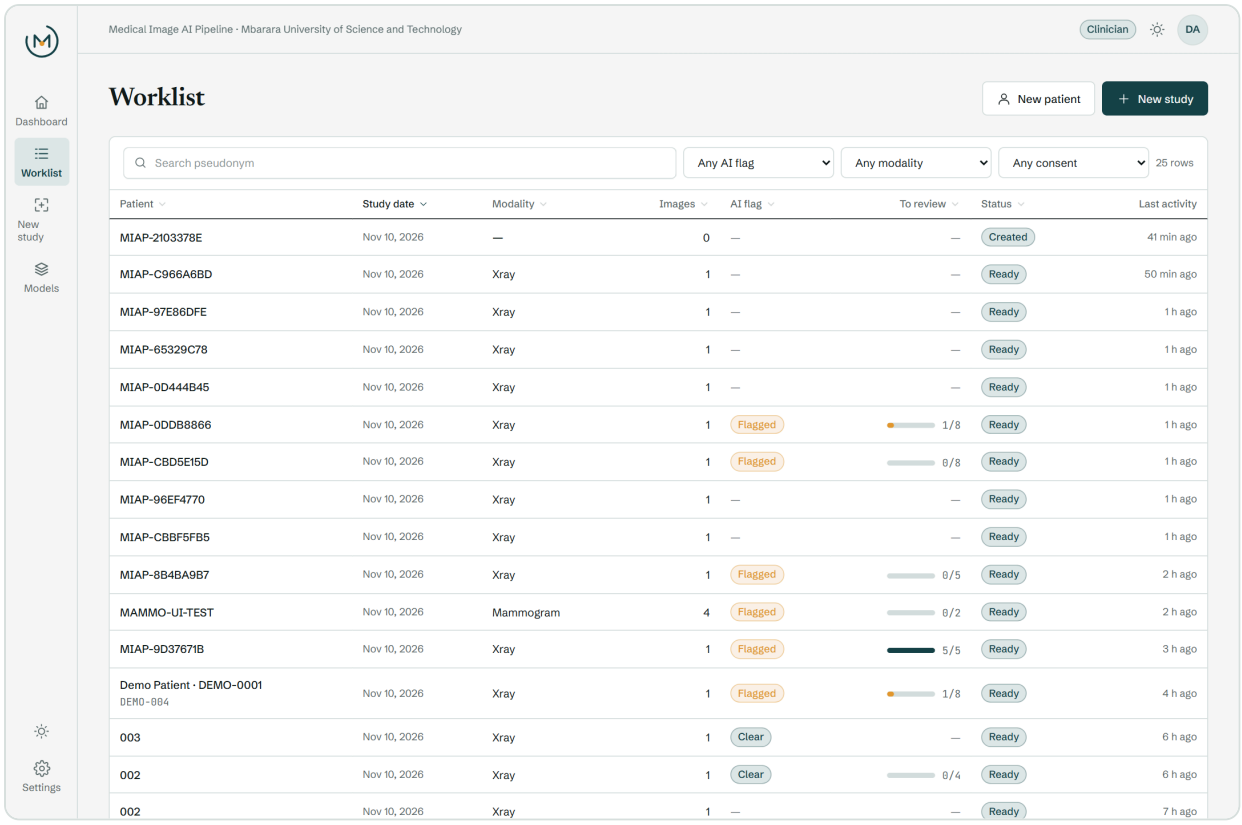
The product is one codebase with three different views. Navigation, dashboards, data scope, report audience and even the wording of the safety notice change with the role. The server enforces the same boundaries even if a client bypasses the interface.

6.1 Clinician: from study to signed review

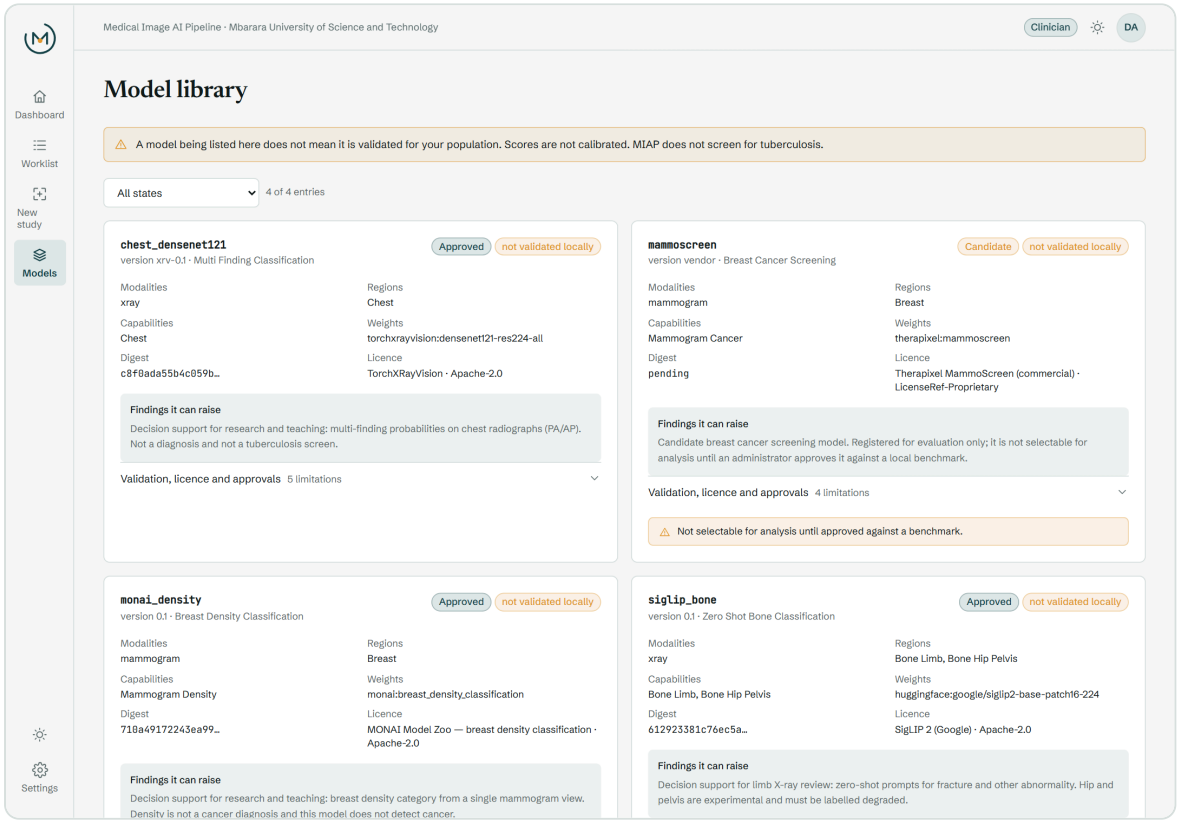
1. **Sign in** and land on a personal dashboard: my patients, open studies, studies flagged by AI, findings still to review and recent work.
2. **Create a study** and optionally a patient identity record (name, hospital number, sex, date of birth). The identity is encrypted and only this clinician can read it.
3. **Upload** a DICOM, PNG or JPEG. The receipt shows what was de-identified and confirms that no re-identification key was kept.
4. **Analyse** from the workspace. The server selects an approved model for the image's capability bucket. Mammograms are queued one job per view.
5. **Read the impression** first: the leading pattern in plain language, or the density category, or an explicit "no finding reached the review band" statement.
6. **Inspect the evidence:** each finding has a plain label, a qualitative band, a thin score bar and a review state. Selecting a finding loads its own CAM.
7. **Confirm or dismiss** each finding and optionally add a note. Progress updates inline. Nothing opens a new window.
8. **Create the clinical PDF** last. It carries identity, the impression, findings, decisions and notes, a selected overlay, caveats and a technical footer.



Clinician dashboard. Personal worklist, patients, open studies, AI-flagged studies, findings awaiting review. The single safety notice sits at the bottom and combines decision support with the TB non-screening statement.



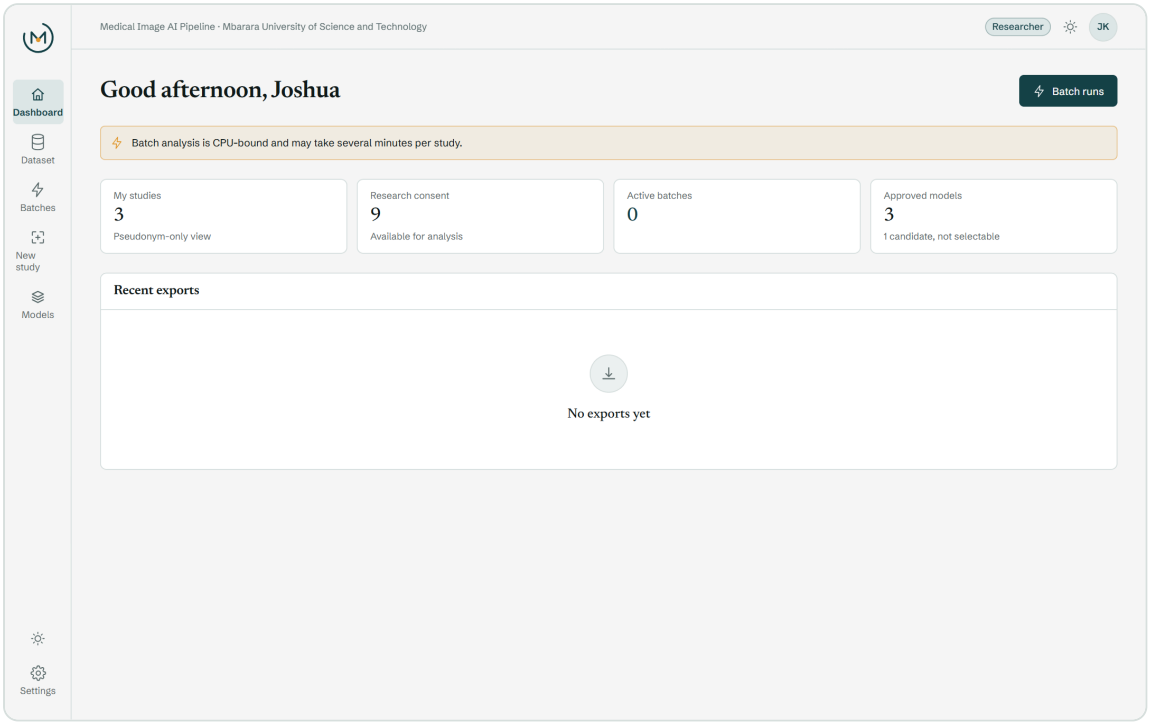
Worklist. Server-side sorting and filtering, AI status, review progress and role-scoped columns. The clinician sees patient identity only for their own linked records; otherwise the pseudonym is shown.



Model library. Clinical roles get a read-only view of what each model does, its licence, source, validation statement and limits. “Approved” means allowed to run, not clinically validated. MammoScreen is visible but unselectable until it passes a benchmark and an approval decision.

6.2 Researcher: dataset, batches and exports

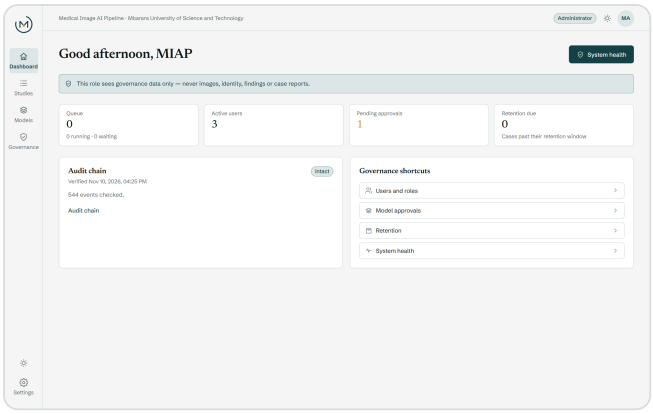
Researchers see their own studies plus cases shared with research consent. They do not see patient identity, review notes or clinical reports. Their dashboard reports dataset counts, active batches and model state, with a compute warning because batch analysis is CPU-bound. They can run batch analyses with per-item idempotency keys, compare model outputs, and create a pseudonymised CSV/JSON export with a row cap; every export is audited.



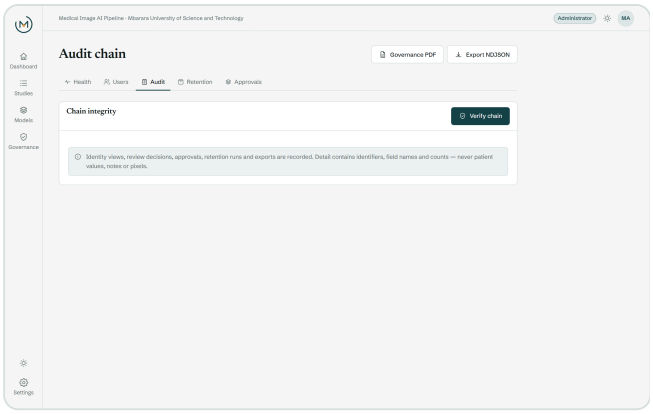
Researcher dashboard. Pseudonym-only dataset, research-consent count, batch queue and model approvals. The operational warning is inline; the clinical safety notice is not shown because this role cannot open clinical cases.

6.3 Administrator: governance without clinical content

The administrator manages users, roles, approvals, retention, system health and the audit chain. The dashboard shows queue depth, active users, pending approvals, retention due, and the last audit verification. There is no viewer, no findings list, no identity and no case report. A separate governance PDF summarises the period: users and roles, model decisions with benchmark evidence, audit status, retention runs and storage totals.



Administrator dashboard. Governance data only. The role notice at the top states the boundary explicitly.



Audit page. Chain verification, event counts and NDJSON export. The chain is checked independently by `scripts/verify_audit.py`.

6.4 Interface decisions that matter clinically

One safety notice, not many

Non-critical disclaimers are combined into a single block at the bottom of each screen and de-duplicated. Critical or functional notices stay inline: administrator no-pixel access, result/view mismatch, demo or degraded model, unavailable candidate model, and encrypted review notes.

A stationary viewer

At desktop width the viewer is a sticky centre column. Approving or dismissing a finding does not move the image or open a modal; the review controls are inline beside the evidence. Below 1280 px the findings panel becomes a drawer.

An impression, then evidence

The first thing a clinician reads is the conclusion in plain language, not a ranked list of probabilities. The same server-side text is used in both PDF audiences, so the screen and the report cannot drift apart.

A tour, not a manual

Instructional copy was removed from the working screens. A role-aware first-run tour explains navigation, can be skipped, and is reopenable from Settings. Operational help belongs in onboarding, not in every panel.

7. Models and AI outputs

MIAP does not have one general model. It has a small registry of models, each with a declared capability, preprocessing profile, licence, source, validation statement and approval state. The router chooses a model only if it is approved and covers the image.

7.1 What is in the registry

Model	Task and capability	Input and CAM	State	Validation statement
`chest_densenet121` xrv-0.1	Multi-finding chest classification; bucket `chest`	224×224, TorchXRayVision normalisation, centre crop; CAM at `features.norm5`	APPROVED	Upstream public-dataset weights only. No local benchmark until the M0 latency gate; no clinical validation on Ugandan or local patients.
`monai_density` 0.1	Breast density A–D; bucket `mammogram_density`	299×299 RGB, resize (not centre crop); CAM at `features.Mixed_7c`	APPROVED	No clinical validation on local patients. CPU gate passed (speed, memory, CAM sanity), not accuracy. Density is not a cancer diagnosis.
`siglip_bone` 0.1	Zero-shot limb X-ray normal vs abnormal; buckets `bone_limb`, `bone_hip_pelvis`	224×224 RGB, mean/std 0.5; CAM on the last ViT block	APPROVED EXPERIMENTAL	No documented dataset provenance, no local validation, no threshold tuning. Hip/pelvis runs with `degraded=true` and a visible caveat.
`mammoscreen` vendor	Proprietary breast-cancer screening	Declared by vendor; engine refuses until benchmarked	CANDIDATE	Registered for evaluation only. Not selectable for analysis. Its benchmark record is an explicit refusal, not a pass.
`stub_classifier` 0.1	Deterministic routing/fallback classifier	Internal only	INTERNAL	Hidden from model lists, health and dashboard counts. Still available to routing and inference. A separate `StubEngine` is the offline fallback when weights are absent.

7.2 Capability routing

The routing service maps modality plus body region or mammogram view to one capability bucket. A model declares the buckets it covers. Selection requires an approved model whose capability matches; otherwise the request returns 409 with the bucket name. There is no silent fallback to a chest model for an unsupported region.

Bucket	Examples	Behaviour
`chest`	PA/AP chest X-ray	Chest DenseNet-121 with per-finding CAM.
`bone_limb`	Hand, wrist, limb radiograph	SigLIP zero-shot normal/abnormal.
`bone_hip_pelvis`	Hip or pelvis radiograph	Same engine, result marked `degraded` and shown with an experimental caveat.
`mammogram_density`	LCC, LMLO, RCC, RMLO	MONAI density per view; exam summary takes the highest category per breast.
`unsupported` / `unrecognised`	Spine, abdomen, skull, CT, MRI	409 naming the bucket. The UI disables analysis and explains the limit.

7.3 What the models actually output

Chest

- Up to eight findings (for example lung opacity, cardiomegaly, atelectasis, effusion).
- Each has a raw probability, a threshold (default 0.5) and a qualitative band.
- A primary CAM is computed synchronously; other findings' CAMs are computed on first request and cached.
- An overall impression names the leading finding at or above the review band.

Mammogram and bone

- Density returns A–D per view. The exam summary reports the highest category per breast and flags a single-view breast.
- Bone returns a zero-shot normal/abnormal score, not a fracture location and not a diagnosis.
- Neither output is a cancer or fracture probability.

7.4 Benchmarks and the delivery gate

Gate	Measured result	What it proves
M0 hardware and chest	665.5 ms mean inference, 689 ms p95, 852 MB peak RSS, 12 images. Masking the CAM hotspot dropped "Lung Opacity" from 0.8694 to 0.6767 (–22.2%).	The target laptop can run the chest model; the CAM is causally related to the score. Not accuracy.
MONAI density	0.109 s mean per view; 2.652 s first result including a 299×299 CAM; 465 MB peak RSS.	Meets the CPU latency gate; CAM is sane. Not accuracy.
SigLIP bone	0.331 s mean; 3.429 s first result including a 224×224 CAM; 2.08 GB peak RSS.	Runs within budget on a hand fixture. Not accuracy.
MammoScreen	Explicit refusal: not benchmarked, not approvable.	Candidate models cannot be selected.

Benchmark JSON files carry a stable digest. An administrator approval stores that digest, and the engine factory re-checks the registry digest on load. A swapped weights file raises `409 model_digest_mismatch` instead of running silently.

7.5 From raw scores to a clinical sentence

The stored result document is immutable. On read, a presenter upgrades it to v2 and adds bands, plain-language labels, per-finding review state and a single **impression**. The same presenter feeds the workspace and both PDF audiences, so the screen and the report cannot disagree.

Situation	Kind	Impression text
Leading finding above the band	`finding`	“Most likely pattern: Lung Opacity (a cloudy patch in the lung). Worth reviewing.”
Leading finding is borderline	`finding`	“Possible pattern: Nodule (a small rounded shadow). The signal is weak and needs clinical judgement.”
Nothing reaches the band	`none`	“No finding reached the review band. This does not exclude disease.”
Mammogram density	`density`	“Breast density category C: dense breast tissue.” No probability of cancer is implied.

The band is qualitative: `above_threshold`, `borderline` or `below_threshold`. Raw scores are shown only in the technical expander and researcher views, always labelled uncalibrated. A score of 0.68 is not a 68% chance of disease.

7.6 Why the models are not evidence of accuracy

The chest weights come from a union of public chest-radiograph datasets whose labels are annotations, not confirmed diagnoses. MONAI density comes from a public model zoo. The bone model is zero-shot and has no documented dataset provenance. None has been validated on Ugandan patients, and no local sensitivity, specificity or AUROC has been measured. The benchmarks intentionally test latency, memory and heatmap sanity because those are the questions a deployment gate can answer honestly at this stage. Accuracy requires labelled local data and a prospective evaluation, which is future work.

> **Model approval is not certification**
>
> An “Approved” badge means an administrator allowed the model to run for decision support, after checking a benchmark digest. It does not mean the model is accurate, calibrated, locally validated or approved as a medical device. The library says “not validated locally” on every card.

8. Reports and model governance

A report is not a screenshot of the results page. It is a rendered view of the same immutable result document, filtered for the audience. Three audiences exist because the clinician, the researcher and the administrator need different information and are allowed to see different things.

8.1 The three report audiences

Audience	Contains	Deliberately excludes
Clinician case owner	Patient identity banner, plain-language impression and findings, bands, confirm/dismiss decisions and notes, selected CAM overlay, caveats including TB non-screening, small technical footer with model and digests.	Other clinicians' cases. Researchers and administrators cannot request this audience.
Researcher	Pseudonym only, technical labels, score, threshold and band, per-finding CAMs, provenance and runtime, review agreement counts, model card reference.	Patient identity, review note text (only `has_note`), clinical framing.
Governance administrator	Period, users and roles, model approvals with benchmark evidence, audit-chain status and verification, retention runs, storage totals.	All patients, pixels, findings, identity and case reports.

Audience is chosen by role, not by a user-supplied parameter that could be abused. A clinician defaults to the clinician audience; a researcher defaults to the researcher audience and may not request the clinician one; an administrator is refused case reports and can generate only the governance report. The server records `audience`, `kind`, `template_version` (3.1) and a SHA-256 of the produced file. Creating and downloading are separate audit events with the audience in the detail.

8.2 Model cards, licences and approvals

What a registry entry declares

- Model id, version, digest, task, modalities, regions and capability buckets.
- Licence (SPDX, name, URL, access date) and source (repository, weights URL, SHA-256).
- Preprocessing profile, input size, channels, crop, mean and standard deviation.
- CAM method and target layer.
- Metrics with dataset provenance, and a path to the benchmark evidence.

How approval works

- New models enter as `candidate` and are visible but unselectable.
- A benchmark must pass and write a digest before an administrator can approve.
- Approval, rejection and revocation are recorded in `model_approvals`, which is the source of truth.
- The decision is projected onto `model_versions`; re-seeding never overwrites it.
- Revoking keeps both decisions in the history.

8.3 Retention, export and user administration

Function	Behaviour
Retention preview / run	Administrator previews due studies, counts and bytes, then runs a confirmed deletion. Due blobs, results and reports are deleted; cases are archived; audit events are kept. There is no automatic scheduler; a startup warning and a manual run are the current design.
Researcher export	Pseudonymised CSV or JSON with no identity or notes, row-capped and audited. Administrators cannot export clinical data.
User lifecycle	Administrator creates users, changes roles, deactivates accounts and issues password resets. Hashes are never returned.
System health	Database, disk, queue depth, worker state, model cache and versions. No patient or case content.
Settings	Personal theme and viewer defaults; researcher default model and export format; administrator retention defaults, export cap and TB notice. The “what your role can see” panel comes from server capabilities, not client duplication.

9. What changed from the original plan

This is the section to read if you know the original document and want to know why the repository does not look exactly like it. Nothing was dropped silently: every change below is either a deliberate narrowing, a substitution, or an addition that the original document did not anticipate.

9.1 Requirement-by-requirement

Original requirement	Delivered	Why	Status
Twelve role-specific screens	Role-specific routes around a unified workspace; admin split into five governance pages.	Separate Analysis and Results screens duplicated state and forced navigation. One workspace keeps the image stationary while findings are reviewed.	CHANGED
Chest X-ray multi-finding (area A)	TorchXRayVision DenseNet-121, top findings, per-finding CAM, impression, review, report.	Only area with pretrained weights ready to use; chosen for a complete vertical slice.	BUILT
Upper limb normal/abnormal via MURA (area B)	Zero-shot SigLIP 2 bone model, limb and hand, hip/pelvis experimental.	MURA is a dataset, not a model; training and validation did not fit this cycle. Zero-shot gives a runnable limb path without pretending it is validated.	CHANGED
Fracture detection with boxes via FracAtlas + YOLO (area C)	Not built. The bone model returns normal/abnormal, not a box.	A detector needs labelled training and a real evaluation; a box drawn by an untrained model would be misleading.	DEFERRED
Mammogram four-view loading and grouping	Four-view grouping, missing/duplicate view handling, synchronised viewer, per-view jobs.	Built as required and extended to feed the density model one view at a time.	BUILT
Mammogram classification and BI-RADS support	Breast density A-D only. No cancer, BI-RADS malignancy or malignancy probability.	Density is the defensible public model available without local labelled data. A cancer model would require validation the team does not have.	CHANGED
Mammogram detection and segmentation	Not built.	Follows from the missing validated cancer model and labelled data.	DEFERRED
Real multi-view fusion	Not built. Exam summary aggregates density per breast with a caveat.	Fusion without validation would hide which view drove a result. The summary is a deterministic aggregation, not a fused model.	DEFERRED
PostgreSQL and Alembic	SQLite WAL with a numbered SQL migration runner.	Single-node offline deployment; Alembic was disproportionate. The migration runner still records checksums and refuses drift.	CHANGED
Docker, Compose, Nginx, TLS	Local development script; TLS expected from a deployment proxy.	No container runtime was required for the demo. Production packaging remains a deployment task.	DEFERRED
Dataset Manager and Evaluation screens	Research dataset view, batch runs, exports, and offline benchmark scripts.	The screens would have been UI over data the team does not yet hold. Benchmark JSON and model cards cover the evidence need.	CHANGED

Original requirement	Delivered	Why	Status
DICOM SEG output	PNG and NPY heatmaps; no DICOM SEG.	No segmentation model exists, so there is nothing to encode.	DEFERRED
Administrator must not see images [ADDED]	Enforced 403 on pixels, files, previews, heatmaps and case reports; metadata-only admin view.	Implemented as a hard boundary and tested against the running app, not just hidden buttons.	BUILT
BI-RADS and malignancy kept separate	Density is a separate field and report section; no malignancy probability exists.	The principle is preserved by not inventing a cancer score. Density is explicitly not a cancer diagnosis.	BUILT
Patient-level training splits	No model training in this cycle; principle retained for future work.	The build uses pretrained weights and benchmarks. Any future fine-tuning must use patient-level splits.	DEFERRED
PACS/EHR, federated learning, regulatory approval	Not built.	Explicitly out of the MVP in the original document.	DEFERRED

9.2 What was added beyond the original document

Safety and trust

- Encrypted patient identity and blind-index lookup.
- Confirm/dismiss reviews with encrypted notes.
- Server-computed impression and plain language.
- Audit-before-read and fail-closed identity reads.
- One combined safety notice per screen.

Governance

- Model registry, cards, licences and source digests.
- Benchmark gate and administrator approvals.
- Three report audiences including governance.
- Retention preview/run and pseudonymised exports.
- User lifecycle, system health and settings.

Usability and engineering

- Role dashboards, worklist and settings.
- Design system, dark mode, icon sprite and tour.
- Viewer overhaul: wheel zoom, right-drag W/L, split, shortcuts.
- Lazy per-finding CAM caching and batch/exam jobs.
- Numbered migrations and a migration rehearsal script.

9.3 Build order: planned versus actual

Step	Planned	Actual	Status
0	Hardware test: PyTorch, DenseNet-121	Passed: 665.5 ms mean, 852 MB peak RSS, CAM sanity checked.	BUILT
1	Ingestion, de-identification, login, three roles	Built, plus receipt, audit chain and administrator image denial.	BUILT
2	Modality and region routers, four-view grouping	Built, plus capability buckets and a unified model resolver.	BUILT
3	Cornerstone viewer, plain images, four-view layout	Built, plus overlays, split, shortcuts and DICOM-style corners.	BUILT
4	Chest inference and heatmap	Built end to end, with review, impression and PDF.	BUILT
5	Upper-limb and fracture models	Zero-shot bone model; no fracture detector.	CHANGED
6	Mammogram classification	Density classification only; no cancer model.	CHANGED

Step	Planned	Actual	Status
7	Evaluation scripts, Model Library, report polish	Built and expanded: benchmarks, cards, approvals, three audiences.	BUILT
8	Mammogram detection and segmentation	Not built.	DEFERRED

9.4 How the original risks were handled

Original risk	Disposition
Weak laptop hardware	Tested first; CPU inference meets the demo budget. MONAI 0.109 s mean, SigLIP 0.331 s mean.
Mammography models least certain	Chose one public density model, benchmarked it and kept a cancer model as an unselectable candidate.
Areas B and C need training	Avoided MURA/FracAtlas training by using zero-shot bone; accepted the loss of fracture boxes.
Dataset access takes time	No new credentialed dataset was needed for the demo; the local MIAS sample stays local-only.
Xp-Bodypart-Checker / FleXray unverified	Neither is used. Routing uses DICOM metadata, a fallback classifier and manual selection.
No metadata means no router	Raster uploads warn and require manual modality/region choice or a fallback guess.
Public data does not represent local patients	Stated in every model card, report and this document. No local accuracy claim is made.
BI-RADS is not a cancer probability	Density is reported as a category only; no malignancy probability is produced.
Previous team's numbers unverified	Not reused. All numbers in this build come from recorded benchmarks and tests.

9.5 The build in phases

The repository history is organised as milestones (M0–M6) followed by four enhancement phases. A new member does not need to replay them, but the order explains why some files look layered.

Phase	Focus	Result
M0	Hardware gate, repository scaffold, TorchXRayVision and Grad-CAM feasibility.	160-test baseline later
M1–M2	Backend, auth/RBAC, upload, de-identification, routing, mammogram grouping.	Working pipeline
M3–M4	Cornerstone viewer, chest inference, CAM overlay, immutable result and provenance.	End-to-end chest path
M5–M6	PDF report, model library, audit export, hardening, crash recovery, demo run.	Demonstrable MVP
Foundation	Migrations, encrypted identity, reviews, role APIs, audit hardening.	223 tests
Design/UI	Design system, role screens, unified workspace, viewer overhaul.	224 tests

Phase	Focus	Result
Reports/models	Three report audiences, registry/cards/approvals, MONAI and SigLIP engines, benchmarks.	267 tests
Copy/tour	Instructional copy removed, first-run tour, internal router hidden.	268 tests
Declutter/impression	One safety notice, sticky workspace, inline review, impression, PDF impression.	271 tests

10. Verification and evidence

Every claim in this document should be traceable. The backend suite, benchmark JSON, screenshots, PDFs and audit exports live in the repository. The numbers below are the ones a new member can reproduce.

10.1 Test suite growth

Checkpoint	Backend tests	What was added
M1–M6 baseline	160 → 162	Auth, RBAC, upload, de-identification, audit, report overlay compositing.
Foundation	223	Migrations, crypto/AAD, DB-byte scans, RBAC matrix, identity audit, reviews, presenter v1→v2, heatmap uniqueness, batch idempotency, approvals.
Design/UI	224	Batch list role/limit test.
Reports/models	232 → 238 → 267	Audience separation, registry metadata, engines, exam summary, MONAI end to end, SigLIP hand/hip.
Copy/tour	268	Internal router model hidden from lists.
Declutter/impression	271	Three impression tests: leading condition, borderline/absence, density category.

On 10 November 2026 the full suite ran in 42.39 s: **271 passed**. The front end typechecks clean with `tsc --noEmit` and builds with Vite. These are correctness checks for the code, not proof that the clinical feature is correct; the manual and browser checks below cover behaviour.

10.2 Browser and end-to-end evidence

- **Full demo (M6):** clinician sign-in, study creation, DICOM upload with de-identification receipt, chest analysis, result and overlay, PDF creation, administrator audit verification (87 events), NDJSON export, and a **403** when the administrator requested image pixels.
- **Crash recovery:** the server was killed while a job was running; on restart the job was re-queued and completed (states `running → completed`, attempts 2).
- **Viewer geometry:** rendered hotspot vs stored CAM argmax differed by about 0.002 of image width; overlay stayed registered through zoom.
- **Mammogram:** a four-view study scored 4 of 4; left and right breast both category B; the pre-approval state correctly disabled the exam action.
- **Responsive checks:** 1440, 768 and 360 px across roles; no horizontal overflow, no console errors, no computed font below 12 px.
- **Current UI (this document):** fresh 1440 px screenshots of clinician dashboard, worklist, workspace, models, settings, researcher and administrator dashboards, and the audit page.

10.3 Reproduce the core checks

```
# from the repository root
.venv/Scripts/python -m venv .venv                  # once
.venv/Scripts/python -m pip install -r backend/requirements.txt -r backend/requirements-dev.txt
cd backend && ../.venv/Scripts/python -m pytest -q  # 271 tests

cd ../frontend && npm ci && npm run typecheck
npm run build

# model integrity and benchmarks
python scripts/fetch_models.py --check
python scripts/verify_models.py
python ml/benchmark/bench_model.py --model monai_density
python ml/benchmark/bench_model.py --model siglip_bone

# audit verification on an export from the admin UI
python scripts/verify_audit.py path/to/audit.ndjson
```

10.4 What the evidence proves — and what it does not

It proves

- The pipeline runs end to end on CPU and offline.
- Role boundaries, identity encryption, de-identification and audit ordering behave as specified under test.
- The models load, meet the latency/memory gate and produce sane CAMs.
- The three report audiences separate identity, technical detail and governance correctly.
- The UI works at desktop and mobile widths with no console errors.

It does not prove

- Diagnostic accuracy, calibration or safety in a real population.
- That a heatmap marks the lesion rather than a correlated area.
- That the bone or density models generalise beyond their public data.
- That de-identification catches burned-in text or free-text identifiers.
- That the audit chain survives an attacker with database write access.

Where the evidence lives

`docs/MILESTONES.md` is the chronological record with commands and numbers. `docs/evidence/` holds screenshots, PDFs, benchmark logs and the current explainer screenshots. `ml/benchmark/` holds machine-readable benchmark JSON. `docs/API.md`, `docs/ARCHITECTURE.md` and `docs/DEID.md` are the reference documents.

11. Why decision support, not diagnostic

“Decision support” and “diagnostic” are not marketing labels. They describe what the output is allowed to mean and what evidence stands behind it. MIAP is decision support because its output informs a clinician’s judgement; it does not establish whether disease is present.

11.1 The six reasons

Reason	What this means in MIAP
Scores are uncalibrated	A raw model score is not a probability of disease. The app uses a fixed 0.5 threshold and qualitative bands, and shows raw numbers only in the technical or researcher view, labelled uncalibrated. A score of 0.68 does not mean a 68% chance of disease.
No local validation	The chest model uses public-dataset weights; the density model comes from a public zoo; the bone model is zero-shot with undocumented provenance. None has been validated on Ugandan or local patients, and no sensitivity, specificity or AUROC has been measured locally.
The evidence is about speed, not accuracy	The benchmarks measured latency, memory and CAM sanity. That is a deployment gate, not a clinical evaluation. The model cards say so explicitly.
Coverage is narrow	Chest findings, breast density and limb normal/abnormal. MIAP does not screen for TB, does not detect cancer, does not localise fractures, and does not answer “is this patient sick”. A low score does not exclude disease.
The heatmap is attention, not pathology	Grad-CAM shows where the model looked. It is not a lesion outline, and areas outside the model input carry no heatmap and are not evidence of normality.
A clinician decides	Findings require Confirm or Dismiss; reports carry a decision-support statement; there is no autonomous action, no PACS write-back and no patient-facing output. The clinician retains responsibility.

11.2 The regulatory consequence

Calling a system diagnostic would make it a medical device. That would require, at minimum, prospective local validation, calibration and locked thresholds, a quality-management system, regulatory approval and post-market surveillance. MIAP does not have that evidence, so it is positioned where its evidence supports it: a decision-support tool under clinician responsibility. The approval workflow in the model library is a *deployment* decision, not a certification.

> **A simple test for new group members**
>
> If a sentence says “the patient has X”, it is a diagnostic claim and MIAP must not make it. If a sentence says “the model found a pattern that may be X; a clinician should review it”, it is decision support. The impression text, report wording, API fields and UI labels are all written to the second pattern. Keep it that way when you extend the system.

11.3 What would have to change to become diagnostic

1. A labelled, representative local dataset with patient-level splits and a pre-registered evaluation plan.
2. External validation on a different source, with sensitivity, specificity, calibration and subgroup reporting (including breast density where relevant).
3. Threshold selection and calibration locked before evaluation, not tuned on the test set.
4. A prospective or silent-mode clinical study with a safety monitoring plan.
5. Quality management, version control of weights and data, incident reporting and post-market surveillance.
6. Regulatory review and a clear intended-use statement that matches the evidence.

Until all six exist, adding a “diagnosis” label to the interface would be a claim the project cannot defend.

12. Current limits and open items

This is the honest gap list. It is deliberately specific so that the next group can plan rather than rediscover. Nothing here is hidden in the interface: the product says the same things to its users.

12.1 Clinical and evidence limits

Limit	Consequence
No local clinical validation	No accuracy, sensitivity, specificity or calibration claim is possible for the local population.
Uncalibrated scores	Bands are qualitative. A raw score cannot be read as a probability of disease.
No TB screening	A low or negative result does not exclude tuberculosis; the local TB pathway must be used.
No cancer or BI-RADS malignancy model	Mammography reports density only. Density is not a cancer diagnosis.
No fracture detector	The bone model returns normal/abnormal; there are no boxes or fracture types.
Bone model experimental	Undocumented dataset provenance; hip/pelvis runs marked `degraded` with a caveat.
Single-view mammogram caveat	One view can carry a breast's category; single-view density is less reliable than a complete exam.
Heatmap is not a lesion map	It shows model attention, not proof of disease, and covers only the model input area.
Population bias	Public training data is not representative of Uganda; performance may not transfer.

12.2 Technical and operational limits

Limit	Consequence / next step
SQLite single node	No horizontal scaling or object storage. PostgreSQL is a future migration, not a current capability.
Audit chain single-process assumption	`BEGIN IMMEDIATE` closes the cross-session fork window but assumes one application process. An outbox or database-level sequence would be needed for multi-process deployment.
Tamper-evident, not tamper-proof	Database write access can replace the chain. Restrict file permissions and export regularly.
Fixed de-identification subset	No burned-in-text OCR or inpainting; no configurable profile or date shifting. Manual review is required before sharing.
No PACS/EHR integration	Upload is manual. No DICOM SEG, no worklist query, no report write-back.
No automatic retention scheduler	Retention is a manual administrator run with a startup warning.

Limit	Consequence / next step
No current-versus-prior comparison	Each study is interpreted on its own.
No notifications or i18n	No email/alerting; interface and server plain language are English-only.
No Docker/Nginx/TLS in development	Development is HTTP on localhost. Production packaging and TLS are deployment tasks.
No E2E suite in CI	Browser checks were run manually; screenshots are the evidence. CI should add pytest, typecheck and a small Playwright smoke test.
Weights not committed	A fresh checkout must run `fetch_models.py` once; the stub engine is available without weights.

12.3 Governance and project limits

- **Lawful basis and ethics review** for real patient data are not complete. The project currently uses synthetic and demonstration data.
- **No local dataset or evaluation protocol** exists yet; patient-level splits and external validation remain future work.
- **Ownership of backend, frontend and models** is not recorded in the repository. This should be agreed and written down.
- **MammoScreen** remains a candidate with a proprietary licence; using it would require a vendor agreement, a benchmark and an approval decision.
- **MIAS sample data** is local-only because of its research licence and must not be committed or redistributed.
- **No incident-response or backup policy** is documented beyond the migration backup and purge scripts.

12.4 Recommended next steps

1. **Ethics and data protection first.** Write the lawful basis, DPIA-style assessment, retention policy and consent language before collecting real images.
2. **Build a local evaluation set.** Curate labelled, representative studies with patient-level splits; pre-register metrics and subgroups.
3. **Choose one clinical question** for the next model cycle. Fracture detection and mammography cancer risk are different projects; do not fake either with an unvalidated model.
4. **Add CI.** Run pytest, typecheck, build and a minimal Playwright smoke test on every change; keep benchmark JSON as an artefact.
5. **Package deployment.** Containerise, terminate TLS at a proxy, define backups, restrict database file permissions and document restore drills.
6. **Harden de-identification review.** Add a manual checklist for burned-in annotation and free-text identifiers; consider OCR detection, not pixel alteration.
7. **Finish the governance loop.** Add a retention scheduler, audit export schedule and a documented approval policy for new model versions.
8. **Write the handover.** Record module owners, the release process, the key/rotation procedure and the open decisions in this section.

13. Running and exploring the project

The project is designed to run on a modest laptop with no GPU and no network at runtime. This section is the shortest path from a fresh checkout to a working demo, followed by a first-day checklist.

13.1 Requirements and setup

```
# Python 3.13 (3.12 also supported), Node.js 22+, no GPU, no Docker
python -m venv .venv
.venv/Scripts/python -m pip install --no-cache-dir torch torchvision --index-url
https://download.pytorch.org/whl/cpu
.venv/Scripts/python -m pip install --no-cache-dir torchxrayvision grad-cam transformers safetensors
huggingface_hub
.venv/Scripts/python -m pip install --no-cache-dir -r backend/requirements.txt -r backend/requirements-dev.txt
cd frontend && npm ci && cd ..

# PII keys are required; the app refuses to start without them
python scripts/gen_keys.py          # appends MIAP_PII_* lines to backend/.env (gitignored)

# weights are not committed; download once and verify every SHA-256
python scripts/fetch_models.py
python scripts/verify_models.py

# demo users (development only; passwords are printed by the script)
python scripts/seed_users.py

# start both servers
scripts/dev.ps1                     # backend :8000, frontend :5173
```

13.2 First-day checklist

1. Read `MIAP_MVP_Pipeline.md` (the scope authority), then this document, then `docs/ARCHITECTURE.md`.
2. Run the backend suite and the front-end typecheck. Confirm **271 passed** and a clean typecheck on your machine.
3. Start the app and sign in as each role. Notice what disappears for the researcher and administrator.
4. Open a demo case with a result. Read the impression, open a finding's CAM, confirm one finding, add a note, then create the clinical PDF.
5. Sign in as the administrator, verify the audit chain and export it. Run `scripts/verify_audit.py` on the export. Try to open an image and confirm the 403.
6. Read two model cards in `ml/cards/` and the benchmark JSON in `ml/benchmark/`. Understand what the gate does and does not prove.
7. Read section 12 and the "not claimed" notes in `docs/MILESTONES.md`. Those are your real backlog.
8. Do not collect real patient data until the ethics and data-protection review is complete.

13.3 Where things live

Path	Contents
`backend/app/`	FastAPI application: `core/` (config, DB, crypto, audit, migrations, security) and `modules/` (one package per domain).
`backend/tests/`	271 tests covering the RBAC matrix, crypto, migrations, reviews, presenter, engines, reports and edge cases.
`frontend/src/`	`pages/` (role screens), `components/` (shell, ui, workspace, viewer, patient), `api/client.ts`, `lib/cornerstone.ts`.
`ml/`	`registry.json`, `cards/`, `benchmark/`, gitignored `weights/`.
`migrations/`	Numbered SQL schema files, including the reviewed `001_init.sql` snapshot.
`scripts/`	Key generation, key rotation, model fetch/verify, audit verification, migration rehearsal, seed users, purge, dev launcher.
`docs/`	Architecture, API, de-identification, milestones, ADRs, evidence, this explainer.
`data/`	Runtime database, blobs, derived CAMs and reports. Gitignored. Contains no committed patient data.
`sample_data/`	Local-only MIAS sample set. Do not commit or redistribute; check the licence.

13.4 Where to make a change

If you want to…	Start here
Add a model	Add a registry entry and model card, implement an engine adapter and preprocessing profile, add a benchmark, then approve through the admin API.
Add a database column or table	Add a numbered SQL file in `migrations/`; update the ORM; rehearse on a copy with `scripts/migrate.py --dry-run`.
Change a role rule	`backend/app/core/deps.py` and the module router; add a test for the allowed and denied case.
Change result wording or bands	`backend/app/modules/results/presenter.py` and `plain_language.py`. The UI and both PDFs read the same output.
Change the look	`frontend/src/index.css` tokens and `components/ui`. Keep the 12 px minimum type and the one-accent rule.
Change a report	`backend/app/modules/reporting/templates/` and `service.py`; keep the audience boundary and the decision-support statement.
Change the viewer	`frontend/src/lib/cornerstone.ts` and `components/viewer/`; retest overlay registration through zoom.

14. Glossary and file map

14.1 Terms used in this project

Term	Meaning here
MIAP	Medical Image AI Pipeline. The project and the application.
CDS	Clinical decision support: information that assists a qualified clinician, who retains responsibility.
DICOM	The standard format for medical images and their metadata. DICOM files carry patient tags, geometry, laterality and view.
PS3.15	The DICOM security standard. MIAP implements a fixed subset of the Basic Application Level Confidentiality Profile.
De-identification	Removing identity from the image and its header. MIAP discards the original bytes and does not retain the UID remapping key.
Pseudonym	A study label that carries no identity, for example `MIAP-0DDB8866`. It is the research key.
PII / PHI	Personally identifiable information / protected health information. In MIAP, the encrypted patient record.
AES-256-GCM	Authenticated encryption used for patient identity and review notes.
AAD	Additional authenticated data. MIAP binds a ciphertext to the patient or review id so it cannot be swapped.
Blind index	An HMAC of a normalised identifier that allows exact lookup without storing the plaintext.
JWT / RBAC	JSON Web Token for login; role-based access control for permissions.
Audit chain	Append-only events where each row hashes the previous one. Tampering is detectable, not impossible.
Grad-CAM / CAM	A heatmap of where a model looked when producing a score. Not a lesion outline.
Band	A qualitative category around the threshold: above, borderline or below the review band.
Impression	The server-computed plain-language conclusion shown in the workspace and both PDFs.
Calibration	The relationship between a score and the actual frequency of disease. MIAP's scores are not calibrated.
BI-RADS	A breast-imaging reporting lexicon. MIAP reports breast density A–D, not a BI-RADS cancer assessment.
Capability bucket	The routing category a model covers: chest, bone_limb, bone_hip_pelvis, mammogram_density.
Candidate / approved	A candidate model is visible but cannot run. An approved model may run for decision support.
Provenance	The recorded model, version, digest, preprocessing, runtime and inputs used for a result.
Idempotency key	A client-supplied key that prevents duplicate analysis jobs on retry.
WAL	SQLite write-ahead logging, used so reads and writes do not block each other.
MURA / FracAtlas	Public musculoskeletal and fracture datasets named in the original plan. Neither was trained on in this cycle.
MIAS	A mammography sample set used locally. Its research licence prevents committing it.
TorchXRayVision / MONAI / SigLIP	The model families behind the chest, density and bone engines.
PACS / EHR	Hospital image archive and electronic health record. Not integrated in this MVP.

14.2 Documentation map

Document	Read it for
`MIAP_MVP_Pipeline.md`	The original scope, screens, pipeline stages, build order and risks.
`docs/ARCHITECTURE.md`	Runtime topology, modules, storage, security model, configuration and failure behaviour.
`docs/API.md`	Endpoints, roles, request/response examples, error codes and the result document.
`docs/DEID.md`	Exactly what is removed, replaced and retained; UID remapping; known limits.
`docs/MILESTONES.md`	Dated evidence per milestone, commands, numbers and open gaps.
`docs/adr/ADR-015`	Why the MVP narrowed the older Phase-2 design.
`docs/adr/ADR-016`	Why numbered SQL migrations and how identity links to cases.
`ml/cards/`	Intended use, training data, validation, limitations and ethical notes per model.
`docs/evidence/`	Screenshots, PDFs, benchmark logs and verification records.

A. Result document v2

The stored result is immutable. The API returns a v2 presentation computed on read; this is what the UI and both PDFs consume. The stored JSON never changes when the presenter or wording changes.

```
{
  "record_id": "p_...", "result_id": "r_...", "job_id": "j_...",
  "document_version": 2,
  "case_id": "c_...", "image_id": "i_...",
  "modality": {"value": "xray", "method": "dicom_metadata", "confidence": 0.99},
  "region_or_view": {"value": "chest", "method": "dicom_metadata", "confidence": 0.95},
  "model": {"name": "chest_densenet121", "version": "xrv-0.1", "digest": "c8f0...", "demo": false},
  "classification": {"label": "Lung Opacity", "probability": 0.6794},
  "findings": [
    {"index": 0, "label": "Lung Opacity", "probability": 0.6794,
     "threshold": 0.5, "band": "above_threshold", "band_label": "Worth reviewing",
     "plain_label": "a cloudy patch in the lung",
     "plain_sentence": "The model marked changes that can be seen with a cloudy patch in the lung.",
     "heatmap": {"format": "npy", "shape": [224, 224], "path": "derived/..."},
     "review": {"decision": "confirmed", "has_note": true, "revision": 1, ...}}
  ],
  "impression": {"kind": "finding", "label": "Lung Opacity",
                 "plain_label": "a cloudy patch in the lung",
                 "band": "above_threshold", "band_label": "Worth reviewing",
                 "probability": 0.6794,
                 "text": "Most likely pattern: Lung Opacity (a cloudy patch in the lung). Worth reviewing."},
  "primary_finding_index": 0,
  "review_summary": {"reviewed": 1, "to_review": 8},
  "heatmap": {"format": "npy", "shape": [224, 224], "path": "derived/..."},
  "warnings": ["..."], "degraded": false,
  "provenance_id": "p_...", "created_at": "..."
}
```

> **Do not change stored documents**
>
> If the wording or bands change, change the presenter. Recomputing or overwriting stored result JSON would break provenance, audit and the ability to reproduce an old report. The stored document is the legal/technical record; the presentation is a view of it.

A.1 Field notes

Field	Meaning
`document_version`	2 for a presented v2 document. Old stored rows are upgraded on read.
`findings[].band`	Qualitative: `above_threshold`, `borderline`, `below_threshold`. Not a probability of disease.
`findings[].heatmap`	Per-finding CAM. The primary CAM exists immediately; others are computed and cached on first request.
`findings[].review`	Decision, revision and `has_note`. Note text is present only for the clinician owner.
`impression`	`kind` is `finding`, `density` or `none`. `text` is the single sentence shown to every audience.
`warnings`	Model, de-identification, degraded-scope or fallback warnings. The UI filters generic duplicates and combines the rest into one safety notice.

B. Roles and endpoints

This is an orientation map, not a replacement for `docs/API.md`. The API has approximately 50 operations; the table groups the ones a new member will use first.

Area	Representative endpoints	Who
Auth	`POST /auth/login`, `GET /auth/me`	All authenticated roles
Cases and worklist	`POST/GET /cases`, `GET /cases/{id}`, `DELETE /cases/{id}`	Clinician, researcher; admin metadata only
Patients	`POST /patients`, `GET /patients`, `GET /patients/lookup`, `PATCH /patients/{id}`	Clinician owner only
Images	`POST /cases/{id}/images`, `GET /images/{id}/pixels`, `preview.png`	Image readers; admin denied
Analysis	`POST /analyses`, `POST /analyses/exam`, `POST /analyses/batch`, `GET /analyses/{job}`	Clinician, researcher
Results	`GET /analyses/{job}/result`, `GET /analyses/{job}/provenance`, heatmap routes	Case readers; admin status only
Reviews	`POST /results/{id}/findings/{index}/review`, `GET /results/{id}/reviews`	Clinician owner; researcher counts
Reports	`POST /reports/{case}`, `GET /reports/{id}.pdf`, `POST /governance/reports`	Clinician/researcher; governance admin
Models	`GET /models`, `GET /models/{id}`, approval routes	Read: all; approve: admin
Dashboard / settings	`GET /dashboard`, `GET/PATCH /settings/me`, `GET/PATCH /settings/system`	Role-specific
Administration	`/users`, `/system/health`, `/retention/*`, `/audit/*`	Administrator
Research	`POST /exports`, `GET /analyses/batches`	Researcher

B.1 Error shape

Errors are RFC 9457 `application/problem+json` with a stable `code`. The front end keys messages off the code, not the prose. Common codes: `analysis_not_supported`, `model_not_approved`, `model_scope_mismatch`, `model_digest_mismatch`, `idempotency_conflict`, `images_forbidden`, `identity_decrypt_failed`, `result_not_ready`, `report_file_missing`.

B.2 Error and safety vocabulary

Code	What it means for the user
`analysis_not_supported`	The image's capability bucket has no approved model. The message names the bucket.
`model_not_approved`	The selected model is a candidate or was revoked. It cannot run.
`images_forbidden`	The role is not allowed image content. Administrators always receive this on pixel routes.
`identity_decrypt_failed`	The identity ciphertext could not be read. No detail is returned; the failure is audited.
`result_not_ready`	The job is queued or running. Poll the job; do not show a partial result.

C. Evidence index

The repository records evidence rather than relying on memory. These are the files to open when you need to verify a claim in this document.

File or directory	What it shows
`docs/MILESTONES.md`	Chronological record: commands, test counts, benchmark numbers, open gaps, amendments.
`docs/API.md`	Complete endpoint reference, roles, examples, result document, error codes.
`docs/ARCHITECTURE.md`	Topology, modules, storage, security model, configuration and known limits.
`docs/DEID.md`	De-identification profile and its limits.
`docs/adr/ADR-015-mvp-scope.md`	Why the MVP narrowed the earlier Phase-2 design.
`docs/adr/ADR-016-migrations-and-identity.md`	Migration runner and identity-link decisions.
`ml/benchmark/m0_report.json`	Hardware gate: latency, memory, CAM sanity.
`ml/benchmark/monai_density_benchmark.json`	Density latency, memory, CAM gate and digest.
`ml/benchmark/siglip_bone_benchmark.json`	Bone latency, memory, CAM gate and digest.
`ml/benchmark/mammoscreen_benchmark.json`	Explicit refusal: candidate not benchmarked.
`ml/cards/*.json`	Intended use, training data, validation, limitations, ethical notes.
`docs/evidence/phase2-*.png`	Role dashboards, worklist, workspace, models, settings at 1440/768/360 px.
`docs/evidence/phase3-*.png`	Mammogram exam before/after approval, model library approvals.
`docs/evidence/report-*.png`	Fresh screenshots used in this document (current UI).
`docs/evidence/phase3-report-*.pdf`	Clinician, researcher and governance PDF examples.
`docs/evidence/2026-11-10-disclaimers-workspace-impression.txt`	Verification of the latest workspace, warning and impression changes.
`scripts/verify_audit.py`	Independent audit-chain verifier; rejects tampered exports.
`scripts/verify_models.py`	Weights, cards and benchmark evidence checks.
`scripts/migrate.py`	Migration status and dry-run rehearsal on a database copy.

C.1 Final handover summary

Eight things to remember

1. MIAP is decision support. It does not diagnose, screen for TB or screen for cancer.
2. The chest path is the complete reference flow: upload, de-identify, analyse, CAM, review, report, audit.
3. Mammography is density only; the bone model is experimental; there is no fracture detector.
4. Images are de-identified with no re-identification key. Identity is a separate encrypted record, owner-only and audited.
5. Administrators never receive pixels, findings, identity or case reports; they get governance data.
6. Only approved models run. Approval is a deployment decision, not clinical certification.
7. Scores are uncalibrated; bands are qualitative; the heatmap is attention, not proof.
8. The next cycle must start with ethics, local data and validation — not with a bigger model.

Document prepared 10 November 2026 from the repository state and recorded evidence. It contains no patient data or secrets. Where a claim could not be verified, it is labelled as not claimed rather than presented as fact.